Security Assessment Report

Prepared by FusionHawk for Anarock Property Consultants Pvt. Ltd. Scope: repository fusionhawk/Anarock, main @ 21cf217 | Date: 2026-10-16

1. Executive summary

Overall risk: **High**. The largest issues are an outdated Next.js with a critical advisory and weak, bypassable abuse protection on public lead-creation endpoints that write directly into production Zoho CRM. Compared with the previous assessment (2026-10-10) the codebase gained only the scope document (commit 21cf217); no security findings were remediated.

Scope reference: *Anarock CLA Online Listing Platform Scope* (docx in repo). Zoho CRM org 'Anarock Property Consultants Pvt. Ltd' (production, Professional edition) was reachable through the AnarockCRM connector. This assessment is a static review of the code in the repository plus npm audit; no dynamic/penetration testing was performed.

2. Findings

ID	Severity	Finding	Evidence	Recommendation
S-01	Critical/High	Next.js 14.2.35 (and eslint-config-next, tailwindcss build chain) carry known advisories: npm audit reports 13 total (1 critical, 10 high, 2 moderate).	anarock/package.json; npm audit	Upgrade to a patched Next.js release and re-run audit; pin and review lockfile in CI.
S-02	High	Public lead endpoint /api/lead2 has no rate limiting at all; it creates records in Zoho CRM.	api/lead2/route.js (no checkRateLimit)	Add rate limiting, bot protection (CAPTCHA/Turnstile) and honeypot; retire or protect the route.
S-03	High	Rate limiting in /api/leads and /api/lead3 is in-memory per instance and keyed on the client-supplied X-Forwarded-For header, so it is bypassable by spoofing the header and does not hold across serverless instances.	leads/route.js:121-170; lead3/route.js:151-190	Use a trusted proxy IP from the platform, shared store (Catalyst Data Store/Cache) and API Gateway throttling (in scope per SoW).
S-04	Medium	Three overlapping lead-creation endpoints (leads, lead2, lead3) widen attack surface and drift in validation behaviour.	api/lead*/route.js (512-1476 lines)	Consolidate to one validated endpoint behind the API Gateway.
S-05	Medium	Upstream error details (Zoho response details, error.message) are reflected to clients in some paths.	leads/route.js:1016, lead3/route.js:1451	Return generic messages; log details server-side only.
S-06	Medium	No security headers (CSP, HSTS, X-Frame-Options, Referrer-Policy) configured; no CORS/origin check on mutating APIs.	anarock/next.config.mjs	Add headers() in next.config and Origin/CSRF checks on POST routes.

ID	Severity	Finding	Evidence	Recommendation
S-07	Medium	Secrets handled via environment variables (good), but README/.env guidance has no example file and 'defaults to hard-coded IDs' for table IDs; .catalystrc with project/domain IDs is committed.	catalyst.js:8-12; .catalystrc	Remove hard-coded IDs, add .env.example, confirm .catalystrc contains no secrets (none seen).
S-08	Low	dangerouslySetInnerHTML used for JSON-LD (Breadcrumbs, layout) and chart styles. JSON-LD is serialised with a safe helper in Breadcrumbs; confirm layout.js escapes '<'.	Breadcrumbs.js:59; layout.js:76; ui/chart.jsx:64	Escape '<' as \u003c in all JSON-LD output.
S-09	Low	Server-side calls to third parties (Nominatim, Frankfurter) with user-supplied coordinates: validate numeric ranges and cache to avoid abuse of upstream quotas.	api/location/route.js, exchange-rates/route.js	Strict numeric validation and caching.
S-10	Info	Wishlist API is a stub; no authentication exists on any API. Acceptable for public read data, but write/lead routes need abuse controls.	api/wishlist/route.js	Define auth/abuse model before enabling user data.
S-11	Info	Positive: input validation (regex name check, numeric bounds, body-size and content-type checks) in /api/leads; no eval/innerHTML sinks found in app code; no ZCQL string building found.	leads/route.js:100-160, 709-738	Retain and reuse across endpoints.

3. Dependency audit

Package	Severity	Range
next	critical	9.3.4-canary.0 - 16.3.0-preview.10 (includes 14.2.35)
eslint-config-next	high	14.0.5-canary.0 - 15.0.0-rc.1
tailwindcss (transitive chain)	high	0.5.0 - 3.4.19

4. Priority remediation

1) Upgrade Next.js and dependencies. 2) Consolidate lead endpoints and add CAPTCHA + gateway throttling. 3) Add security headers and origin checks. 4) Sanitise error responses. 5) Add secret scanning and npm audit to CI.